

AMARACHI OBIOMA KALU

PhD Candidate • PMP • CISM • CISA • CGE-AUD • CISSP (Candidate)

Evington, VA • (301) 807-6467 • amaraben@yahoo.com • github.com/AmyBKay

PROFESSIONAL SUMMARY

Senior GRC Security Engineer with 15+ years of experience spanning IT and financial audit, project management, and secure information systems design — combined with current, hands-on cloud security engineering practice in AWS and GCP. My foundation is audit and PM: I've led full audit lifecycles end-to-end (planning through issue validation) under SOX, GLBA, and Government Auditing Standards, maintained continuous audit-readiness for NERC CIP (CIP-002 through CIP-013), and as a PMP bring formal project structure — scoped risk registers, remediation roadmaps, cross-functional stakeholder management — to every compliance program I run. Expertise in NIST CSF/RMF, NIST SP 800-53, SOC 2, ISO 27001, FedRAMP, and NERC CIP, paired with practical implementation of Infrastructure-as-Code (Terraform), keyless CI/CD authentication (OIDC/Workload Identity Federation), and policy-as-code compliance gates (OPA/Conftest, tfsec) that turn static compliance requirements into enforced, evidenced controls. Doctoral research in AI GRC, AI model supply chain integrity, and adversarial risk — directly applicable to emerging AI governance requirements.

APPLIED SECURITY ENGINEERING — SELECTED PROJECTS

Hands-on GRC engineering portfolio (Terraform, AWS, GCP, GitHub Actions) — code and evidence at github.com/AmyBKay/cgep-labs

- **Keyless CI/CD Authentication:** Implemented Workload Identity Federation (GCP) and OIDC federation (AWS) for GitHub Actions, eliminating long-lived cloud credentials; scoped trust conditions to a single repository to prevent cross-tenant impersonation.
- **Preventive Policy-as-Code Controls:** Deployed GCP Organization Policy guardrails (service-account key restrictions, OS Login enforcement, uniform bucket access) via Terraform; validated enforcement through deliberate policy-violation testing with captured evidence, not just deployed-and-assumed.
- **CI/CD Compliance Gate:** Built a GitHub Actions pipeline enforcing Conftest (OPA) policy checks and tfsec security scanning pre-deployment; the gate caught and blocked a real high-severity encryption misconfiguration, which was remediated and re-verified before merge.
- **Audit Logging & Evidence Integrity:** Enabled and verified Cloud Audit (Data Access) Logging across Storage, KMS, and IAM services — closing the single most common gap found in cloud security assessments — and implemented Cosign artifact signing with chain-of-custody verification for compliance evidence.
- **OSCAL Compliance Mapping & Control Verification:** Authored NIST OSCAL component definitions mapping Terraform-enforced AWS S3 controls (encryption, access control, audit logging, config management) to NIST SP 800-53 Rev 5 via compliance-trestle; found and remediated a missing audit-logging control, then verified the evidence chain using SHA-256 integrity checks and Cosign signature verification.
- **Custom Compliance Checks for Off-the-Shelf GRC Gaps:** Built a Python proof-of-concept (boto3, moto, Faker, pytest) demonstrating exactly where off-the-shelf GRC platforms (e.g. Vanta, Drata) stop covering an organization and where custom code is required — checks a vendor connector already handles (MFA enforcement, public storage exposure) alongside checks only custom code can perform against internal systems (access-revocation timing, periodic access review). Found and fixed a bug where the termination-access check tested presence/absence only, not actual timing.
- **Automated Compliance Evidence Pipeline & Slack Alerting:** Extended the compliance checks into a full evidence pipeline — timestamped JSON evidence compiled into a human-readable Markdown audit report — and built a Slack bot that evaluates results against a YAML control catalog mapped to SOC 2/ISO 27001 requirements, posting Block Kit alerts to a dedicated channel for any failing control. Scheduled via GitHub Actions so alerts fire daily with no manual step.

CORE COMPETENCIES & TECHNICAL SKILLS

GRC & Compliance Engineering: NIST CSF/RMF, NIST SP 800-53, SOC 2, ISO 27001/27701, FedRAMP, PCI DSS, HIPAA, SOX, NERC CIP, COBIT, OSCAL. Working on ISO 42001 certification.

Cloud Security & Architecture: AWS (IAM, CloudTrail, CloudFormation, OIDC, Security Hub), GCP (IAM, Org Policy, Workload Identity Federation, Cloud Audit Logs), Azure, Cloud Security Posture Management

Infrastructure-as-Code & Automation: Terraform, CloudFormation, CI/CD Pipelines (GitHub Actions, GitLab CI), Policy-as-Code (OPA/Conftest, tfsec), OSCAL authoring & validation (Trestle), Cosign artifact signing, Bash, PowerShell

Programming & Data: Python, Bash, JSON, YAML, XML, OSCAL, SIEM (MS Sentinel, Splunk)

Security Engineering Domains: Secure SDLC, Security Requirements Engineering, Enterprise Security Architecture, Vulnerability Assessment, Penetration Testing, Incident Response - FAIR, Supply Chain Risk Management, Business Continuity & Disaster Recovery, Continuous Monitoring

PROFESSIONAL EXPERIENCE

AI Governance Consultant | Independent – Client: StackAware

July 2026 – Present | Remote

- Review AI-generated responses for accuracy, following detailed evaluation procedures without shortcuts to identify factual errors, unsupported claims, and reasoning gaps.
- Distinguish well-supported conclusions from confident-sounding but unfounded assertions, applying the same rigor used in financial and IT audit engagements to AI-generated content.
- Perform AI governance assessments, evaluating AI systems and organizational processes against emerging governance frameworks, including NIST AI RMF, and internal risk criteria.
- Run ISO/IEC 42001 internal audits, assessing organizational conformance to the AI management system standard and documenting findings for corrective action.
- Contribute to client-facing deliverables, including governance frameworks, risk assessments, and compliance documentation, drawing on doctoral research in AI GRC, model supply chain integrity, and adversarial risk.

Assistant Professor, Computational Sciences | Liberty University

Jul 2021 – Present | Lynchburg, VA

- Teach computer programming (Python, C++), operating systems, computer networks, distributed systems, system administration, cloud computing, and information security at the undergraduate and graduate level — building foundational systems expertise that directly informs my cloud security engineering practice.
- Conduct active research in AI GRC, adversarial machine learning, model supply chain integrity, and AI oversight — directly applicable to emerging AI security engineering requirements.
- Design and assess curriculum aligned with ABET/CAEP accreditation standards and industry best practices, including NIST AI RMF and emerging AI governance frameworks.
- Maintain hands-on technical currency through applied cloud security projects (Terraform, AWS/GCP IAM, CI/CD security pipelines, OSCAL compliance automation) bringing practitioner-grade material directly into coursework rather than teaching theory in isolation.

Cybersecurity Consultant (GRC & Security Engineering) | FISMACS, LLC

Mar 2019 – Jul 2019 | Remote

- Designed and implemented enterprise-level GRC frameworks and secure information system architectures across multiple critical infrastructure sectors, integrating security requirements directly into system design and project lifecycles.
- Led NIST CSF/RMF-aligned assessments and continuous monitoring programs, identifying control gaps and translating findings into technical remediation plans.
- Developed compliance automation artifacts including cybersecurity plans, configuration management plans, and supply chain risk management frameworks aligned with FedRAMP and NIST SP 800-53.
- Conducted vulnerability assessments and penetration testing across enterprise environments; delivered executive-level risk reports with quantified impact and actionable remediation guidance.

Project Consultant (Security & Compliance) | Bullaugen Technology

Jan 2014 – Dec 2018 | Part-time

- Managed end-to-end security and compliance project lifecycles including scope definition, scheduling, risk registers, and compliance roadmaps aligned with PMI/PMP and NIST best practices.
- Conducted risk assessments, compliance evaluations, and operational security audits; identified control gaps and developed prioritized remediation plans.
- Oversaw implementation of security controls and compliance plans across cloud and on-premises systems; coordinated cross-functional engineering and compliance teams.
- Led stakeholder engagement and executive briefings, translating complex technical security findings into clear, business-aligned communications.

Senior Cybersecurity Consultant | Corporate Risk Solutions, Inc.

May 2013 – Dec 2013

- Gathered, organized, and managed evidence repositories to maintain continuous audit-readiness for NERC CIP standards (CIP-002 through CIP-013); compliance audits and network security assessments.
- Conducted gap analyses of IT/OT environments against NIST CSF, ISO 27001, and NERC CIP frameworks; delivered prioritized remediation roadmaps to executive and technical stakeholders.
- Designed and updated enterprise security policies covering access control, incident response, and configuration change management across regulated environments.
- Served as NERC CIP subject matter expert; leveraged AuditBoard and AssurX for ongoing compliance tracking, change detection, and audit evidence collection.

Audit Associate | Ben Ekedebe & Co., Chartered Accountants

Jul 2001 – Aug 2007

- Led all phases of the audit lifecycle — planning, fieldwork, reporting, issue validation — across IT and financial audit engagements aligned with SOX, GLBA, and Government Auditing Standards.
- Identified potential areas of material misstatement; evaluated design and operating effectiveness of client control systems; developed prioritized recommendations to strengthen the control environment.
- Verified account balances, traced transactions, and tested compliance with applicable laws and regulations including SOX across banking and financial services clients.

Business Office Manager | Career Technical Institute NW

Apr 2010 – Feb 2011 | Washington, DC

- Managed institutional accounting operations in alignment with GAAP standards; maintained organized records and clear audit trails per Government Auditing Standards for annual financial and compliance audits; ensured adherence to OMB Uniform Guidance, including robust internal controls and standardized chart of accounts, for federally funded programs.
- Implemented GLBA Safeguards Rule requirements to protect student nonpublic personal information, including regular risk assessments, employee training, and secure data disposal; enforced FERPA-compliant controls governing disclosure of student billing and financial records; maintained PCI-DSS compliance across cashiering and digital payment processing systems.

Information Systems Manager | Mead Medical Group, LLC

Apr 2009 – Jul 2009

- Led compliance initiatives for Medicare and Medicaid regulations; managed EHR data integrity, systems security, and regulatory integration strategies in a HIPAA-governed environment.

Research Analyst (Computer Science) | Bowie State University

Sep 2007 – May 2011 | Bowie, MD

- Project-managed the design and deployment of a Volunteer Scheduling System for the American Red Cross using Agile SDLC and UML modeling; conducted research in network security, health informatics, and pattern recognition.

EDUCATION

Doctor of Philosophy (PhD Candidate), Public Policy — AI Governance & National Security

Liberty University, Lynchburg, VA | 2022–Present | Dissertation: AI GRC, AI Model Supply Chain Integrity, Adversarial Attacks, AI Oversight Authority

Master of Science, Information Technology — Information Assurance & Health IS

George Mason University, Fairfax, VA | 2012

Master of Science, Management Information Systems — Information Systems Security | GPA: 4.00

Bowie State University, Bowie, MD | 2009

Bachelor of Science, Accounting

Abia State University | 2005

CERTIFICATIONS

- Project Management Professional (**PMP**) Active
- Certified Information Systems Auditor (**CISA**) Active
- Certified Information Systems Security Manager (**CISM**) Active
- Certified Information Systems Security Professional (CISSP) Candidate, August 2026
- Certified **GRC Engineer - Practitioner** (CGE-P) July 2026 – Exam Passed; Capstone In Progress
- Certified **GRC Engineer – Auditor** Specialty - Active
- Advanced in AI Audit (AAIA) Candidate, 2026
- Advanced in AI Security Management (AAISM) Candidate, 2026
- Graduate Certificate in Computer Science

SELECTED RESEARCH & PUBLICATIONS

- Accounting Information Systems and Corporate Failures: The Auditors' Stand — A Global Perspective
- Design & Development of a Volunteer Scheduling System for the American Red Cross
- Health Information Sharing and Diagnostic Pattern Recognition Models
- **PROFESSIONAL MEMBERSHIPS**
- Project Management Institute (PMI)
- Information Systems Audit and Control Association (ISACA)